

Course-End Project

Advanced Application Security: Secure Coding, Vulnerability Management & Cyber Resilience

Objective: Attack the Juice Shop vulnerable web application to learn how to identify and exploit common web application vulnerabilities.

Target Application: OWASP Juice Shop (<http://10.49.166.6>)

Steps to be followed:

1. Setting up access to OWASP juice shop.

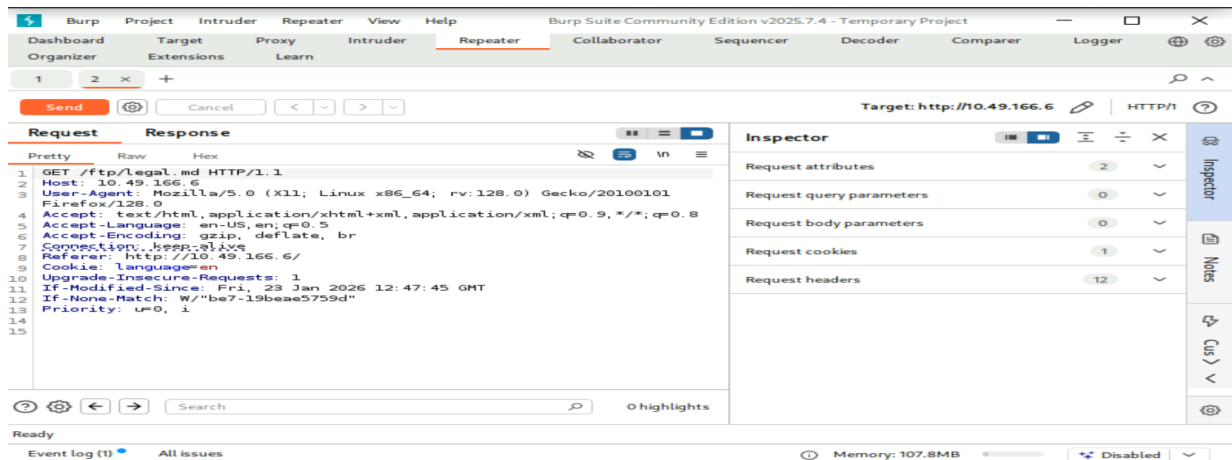
- 1.1. Open the browser and visit **<https://tryhackme.com/>**
- 1.2. Create a free account, search for and open Owasp Juice shop walkthrough.
- 1.3. Open Kali VM and follow the instructions to connect to the OWASP machine with openVPN.

2. Sensitive Data Exposure

- 2.1. Open terminal,
Run the below command for network reconnaissance
`nmap -sV -sC -p- --min-rate 1000 10.49.166.6`
From the result, we observe that tcp ports 22 and 80 are open.
Apache server is running on HTTP through post 80
- 2.2. Access the apache server on the browser with below link
`http://10.49.166.6:80`
It will open a OWASP Juice Shop website
- 2.3. Click on the burger icon on the left side and click on About us.

2.4. In the About us page click on the hyperlink “Check out our boring terms of use.....”

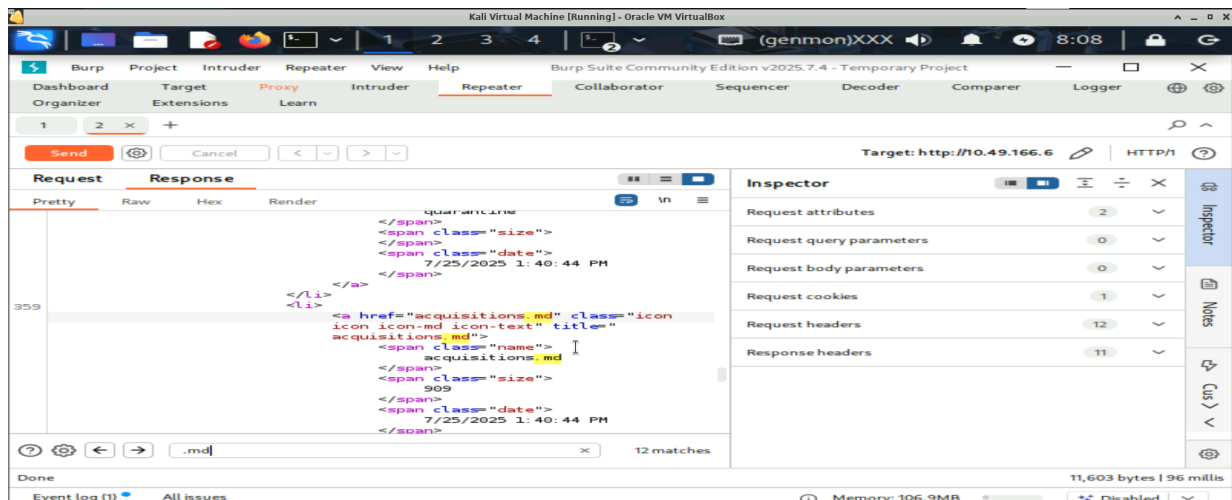
2.5. In Burp suite you can see the get request which was intercepted. Send it to repeater



2.6. Replace the first line with

GET /ftp/ HTTP/1.1

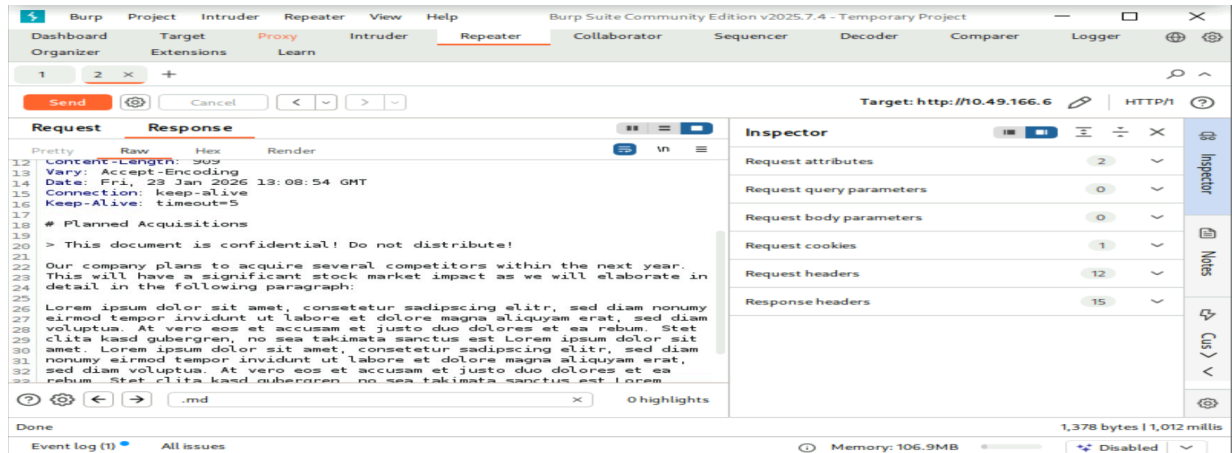
And send it. In the response you can see a list of confidential files.



2.7. Change the request to

GET /ftp/acquisitions.md HTTP/1.1

And you access the confidential file



2.8. Details:

Sensitive documents such as /ftp/legal.md and /ftp/acquisitions.md were publicly accessible due to missing authentication controls.

Exploitation:

By manipulating HTTP requests, an attacker was able to retrieve confidential business files without authorization.

Recommendation:

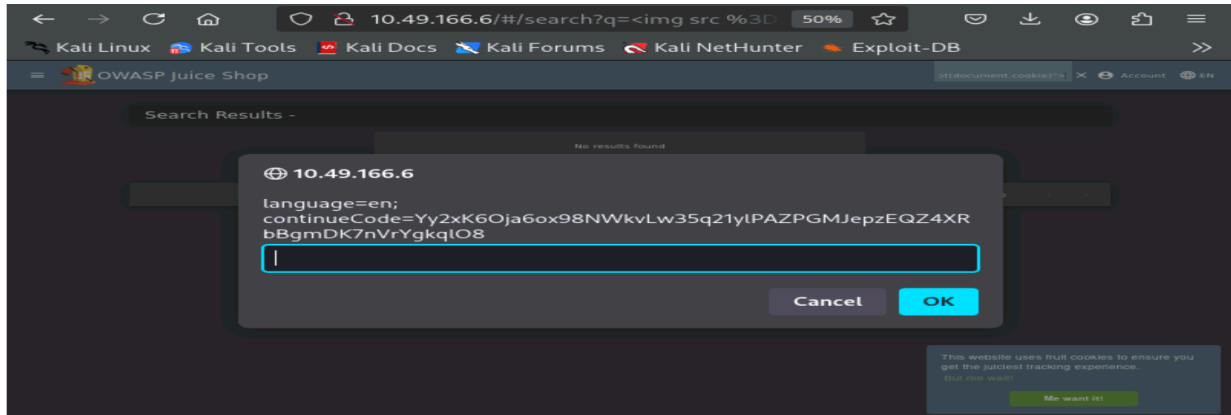
Access control mechanisms should be enforced to prevent unauthorized access to sensitive resources. Implementing directory-level authentication or token-based authorization can help secure protected files.

3. Cross-Site Scripting (XSS)

3.1. Go back to the home page, in search bar type the below input and press enter

```
<img src = x onerror="prompt(document.cookie)">
```

The popup indicates that the site is vulnerable to XSS attacks.



3.2. Details:

The application's search functionality was vulnerable to cross-site scripting, as injecting the payload `<img src=x onerror="prompt(document.cookie)">` successfully executed a browser popup, confirming the presence of XSS.

Exploitation:

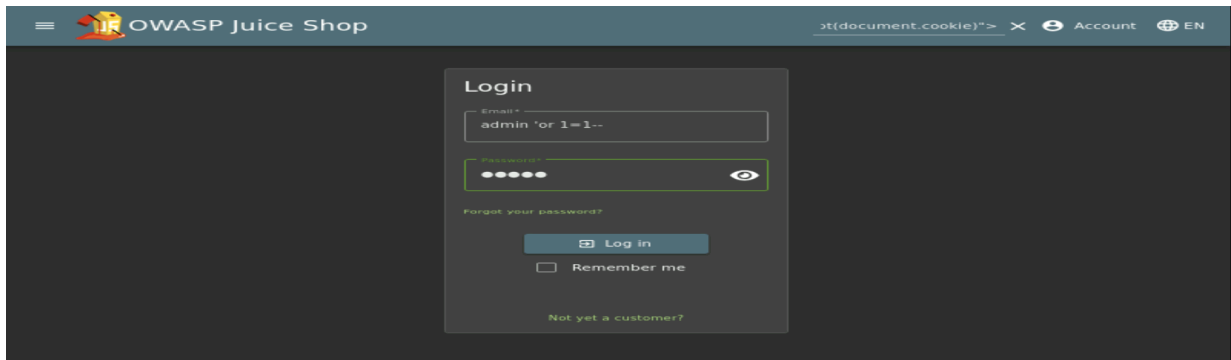
An attacker could leverage this vulnerability to steal session cookies, manipulate page content, or execute malicious scripts in a user's browser.

Recommendation:

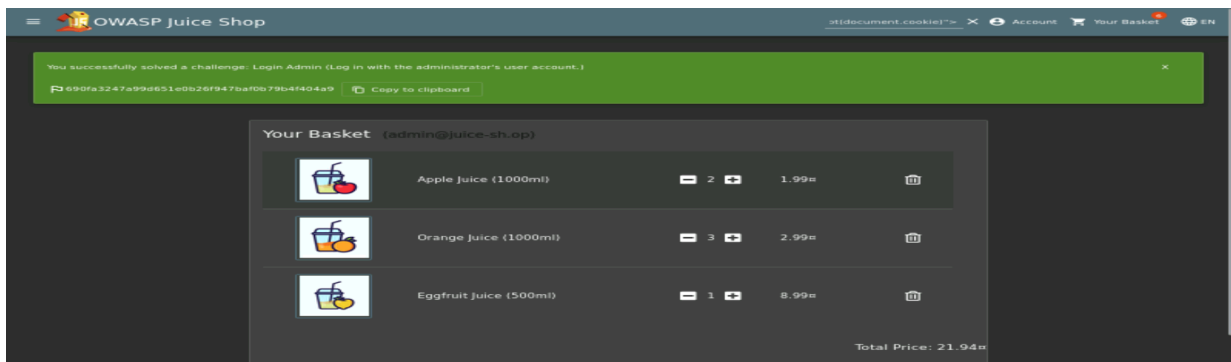
User input should be properly validated and encoded before rendering. Implementing a strong Content Security Policy (CSP) can further reduce the risk and impact of XSS attacks.

4. SQL Injection

- 4.1. Go back to the homepage and access the login page.
- 4.2. In the username type “**admin 'or 1=1--**” and give **admin** as password



- 4.3. Click on Log In and we're able to successfully log in as an Admin.



4.4. Details:

The login interface failed to properly sanitize input, allowing SQL injection payloads such as ' OR 1=1 -- to bypass authentication controls.

Exploitation:

This flaw enabled attackers to gain administrative access and potentially extract sensitive data from the backend database.

Recommendation:

Parameterized queries and prepared statements must be used to prevent SQL injection. All user inputs should be strictly validated and sanitized.

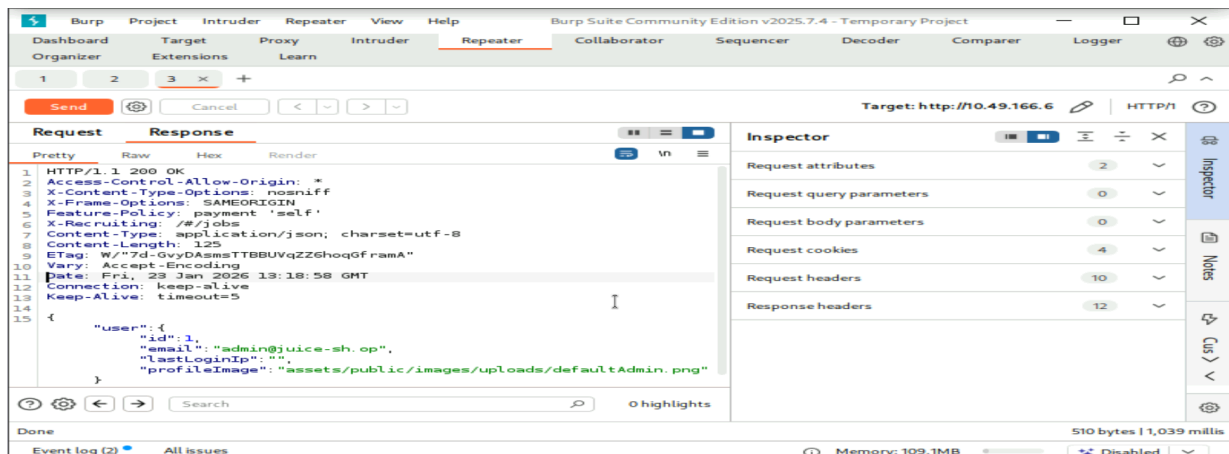
5. Poor Error Handling

5.1. Turn on Intercept in Burp Suite

Back on the homepage of OWASP juice shop and click on any product.

5.2. Send the intercepted request to the repeater.

5.3. In repeater, you can forward the request to the server multiple times and we still see http 200 successful response



5.4. Details:

Modifying API endpoints (for example, changing /rest/user/whoami to /rest/tomato) generated internal server errors that exposed backend implementation details.

Exploitation:

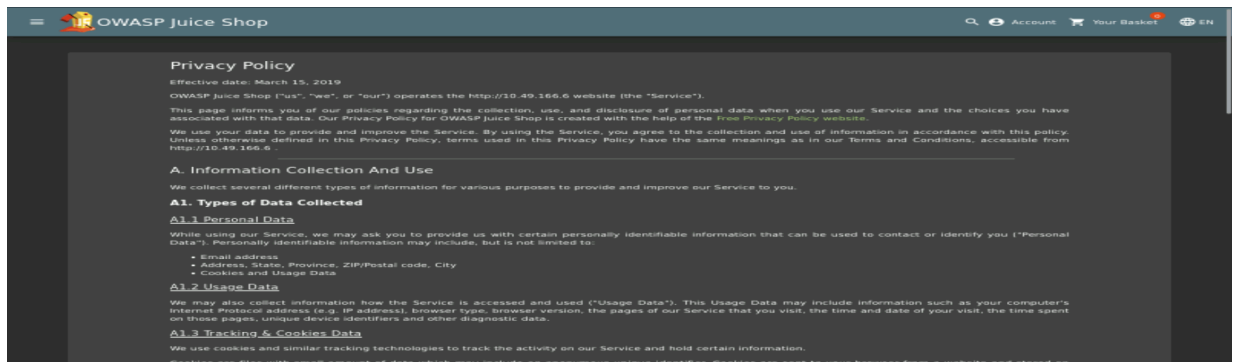
The disclosed information could assist attackers in developing more precise and effective attacks.

Recommendation:

Applications should implement proper error-handling mechanisms, presenting generic error messages to users while securely logging detailed errors on the server side.

6. Privacy Policy Exposure

6.1. Access the Privacy Policy page on the homepage.



6.2. Details:

The Privacy Policy page remained accessible without authentication, even when administrative privileges were in use.

Exploitation:

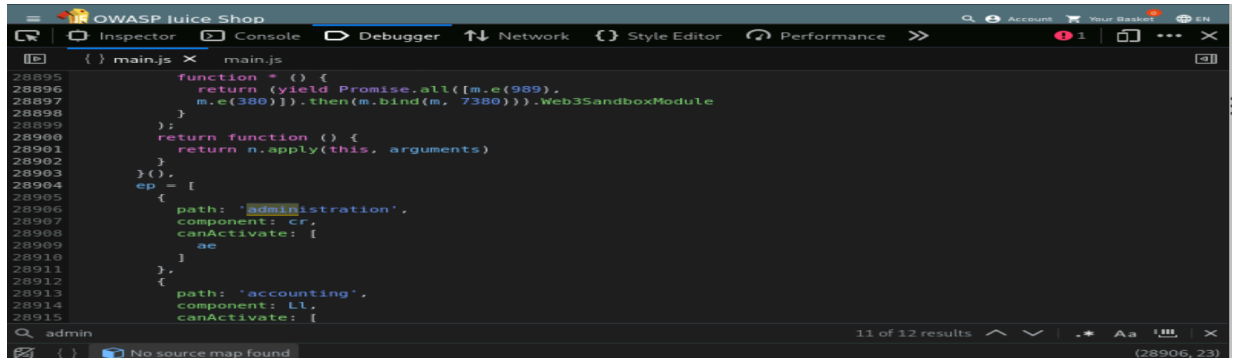
This misconfiguration could lead to unintended exposure of sensitive or user-related information.

Recommendation:

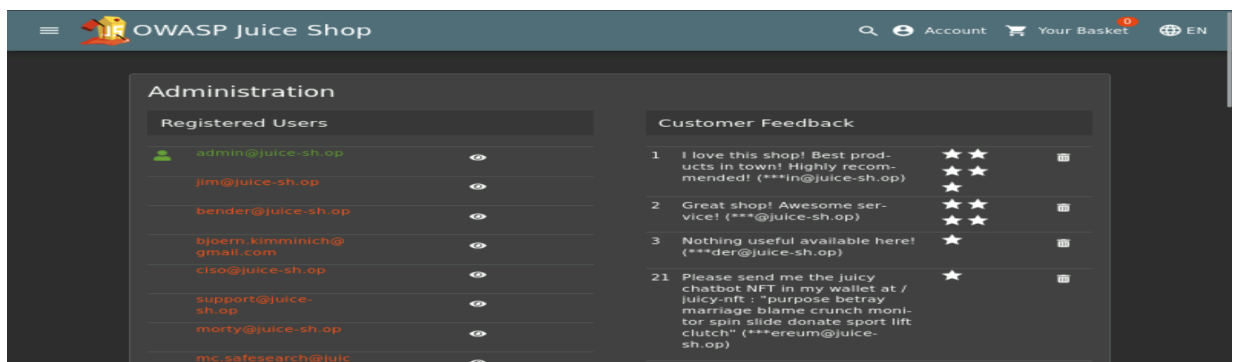
Authentication and authorization checks should be enforced before granting access to sensitive application resources.

7. Broken Access Control

- 7.1. Go back to the homepage
- 7.2. Right click and click on Inspect.
- 7.3. On the Inspect window open Debugger tab and open the **main.js** file
- 7.4. Press Ctrl+F and search for "admin". You will find a path to administration page



- 7.5. Append administration to the url and you will be able to access the restricted page.



7.6. Details:

The administrative interface (/#/administration) was accessible without requiring user authentication.

Exploitation:

This allowed unauthorized individuals to access administrative features, increasing the risk of complete system compromise.

Recommendation:

Strong access control mechanisms such as role-based access control (RBAC) should be implemented, and authentication must be enforced for all privileged endpoints.

8. Database Misconfiguration

- 8.1. Go back to the homepage and logout of the admin account.
- 8.2. Click on the burger icon on the top left to open the side menu and open the Customer feedback page
- 8.3. Turn on Burp Suite intercept.
- 8.4. Enter your feedback and click on the Submit button.
- 8.5. On Burp Suite, you can see the request in Intercept and you can edit its details. Edit the rating to -1 and forward it.
- 8.6. Back on the OWASP website, open the About Us page and you can see the edited review.



8.7. Details:

Improper query handling allowed SQL injection payloads to extract database information, such as through crafted requests to `/rest/products/search`.

Exploitation:

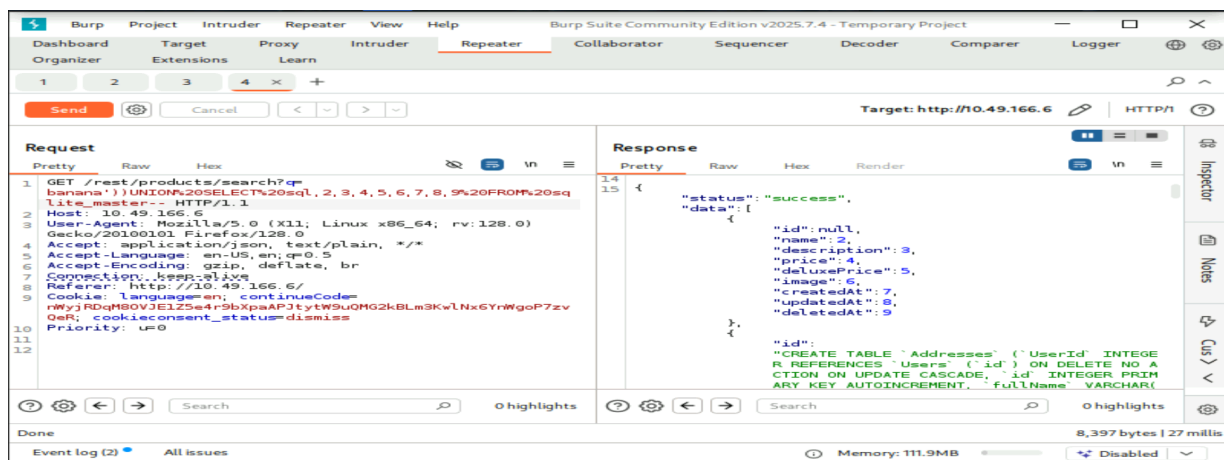
Attackers were able to enumerate database structure and retrieve sensitive records without authorization.

Recommendation:

Database queries and configurations should be reviewed regularly. Deploying a Web Application Firewall (WAF) can help detect and block malicious SQL injection attempts.

9. Database Misconfiguration

- 9.1. Turn on the Intercept.
- 9.2. Click on any product.
- 9.3. In Burp Suite, send the request to the repeater.
- 9.4. Replace the first line of the request with below line and click on Send
GET /rest/products/search?q=banana'))UNION%20SELECT%20sql,2,3,4,5,6,7,8,9%20FROM%20sqlite_master-- HTTP/1.1
We're able to fetch backend database queries in this way



9.5. Details:

Improper query handling allowed SQL injection payloads to extract database information, such as through crafted requests to /rest/products/search.

Exploitation:

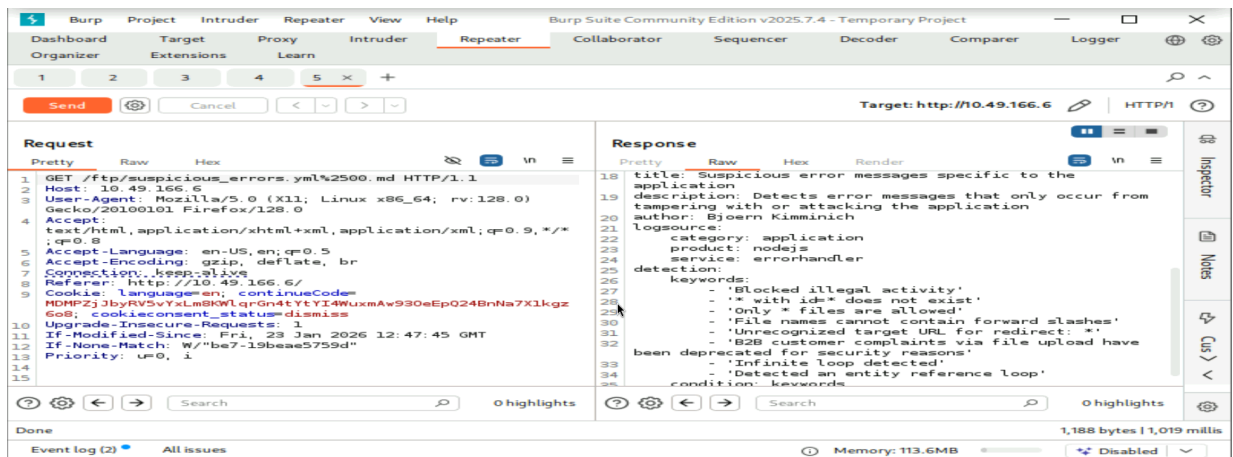
Attackers were able to enumerate database structure and retrieve sensitive records without authorization.

Recommendation:

- 9.6. Database queries and configurations should be reviewed regularly. Deploying a Web Application Firewall (WAF) can help detect and block malicious SQL injection attempts.

10. Exposed SIEM Signature File

- 10.1. Turn on the Intercept.
- 10.2. Open About Us and click on “check out our....” hyperlink.
- 10.3. In Burp Suite, send the request to the repeater.
- 10.4. Replace the first line of the request with below line and click on Send
GET /ftp/suspicious_errors.yml%2500.md HTTP/1.1
We're able to access sensitive error information in this way



10.5. Details:

A sensitive SIEM signature file was publicly accessible through the path /ftp/suspicious_errors.yml%2500.md.

Exploitation:

Exposure of this file could reveal security monitoring rules, allowing attackers to evade detection mechanisms.

Recommendation:

Sensitive configuration and security-related files should be removed from publicly accessible directories and protected using strict access control policies.